

A14 — Matrice des risques

POC Signature Editor — NeoLedge

Table des matières

Objectif	1
Méthodologie	1
Version développement — localStorage, 100 % client.....	2
Version production — hébergement NeoLedge, données transitant par serveur	3
Synthèse comparative	4

Objectif

Ce document recense les risques identifiés pour le POC Signature dans ses deux scénarios de déploiement : la version développement actuelle (application 100 % client, stockage localStorage du navigateur, aucun serveur) et la version production cible (hébergement sur les serveurs NeoLedge, avec persistance et transit des données côté serveur).

Méthodologie

Chaque risque est évalué selon son Impact (I, gravité des conséquences, de 1 à 4) et sa Probabilité (P, vraisemblance d'occurrence, de 1 à 4). La Criticité est calculée par le produit Impact × Probabilité, puis classée selon le barème suivant :

Criticité	Niveau
1 – 3	Faible
4 – 8	Modérée
9 – 12	Élevée
13 – 16	Critique

Version développement — localStorage, 100 % client

#	Risque	I	P	Crit.	Niveau	Mesure préventive
D-01	Perte de données : l'utilisateur vide le cache/historique du navigateur ou change de poste, toutes les signatures sauvegardées sont perdues	3	4	12	Élevée	Informier explicitement l'utilisateur (message UI) que les données sont locales au navigateur ; proposer l'export JSON/PNG comme sauvegarde manuelle
D-02	Quota localStorage dépassé (limite ~5-10 Mo selon navigateur) si beaucoup de signatures/tampons en base64 sont stockés	2	2	4	Modérée	Limiter la taille/résolution des images importées ; nettoyer les anciennes entrées ; afficher une alerte en cas d'échec d'écriture
D-03	Incompatibilité navigateur (API localStorage, Canvas, export PNG) sur un navigateur non supporté du parc informatique	2	2	4	Modérée	Tester sur Chrome, Firefox, Edge, Safari (exigence du cahier des charges) ; détection de fonctionnalités avec message de repli
D-04	Données non partageables entre postes/utilisateurs : une signature créée sur un poste n'est pas visible ailleurs, source de confusion en phase de test	2	4	8	Modérée	Documenter clairement la portée locale de la version dev auprès des testeurs
D-05	Absence de contrôle d'accès : n'importe qui utilisant le poste/navigateur peut lire, modifier ou exporter les signatures stockées localement	3	3	9	Élevée	Accepté pour un POC en environnement de confiance (poste professionnel) ; à lever impérativement avant la mise en production
D-06	Contenu malveillant dans un fichier importé (image/SVG piégé, script embarqué dans un SVG) exécuté côté client	3	2	6	Modérée	Valider le type MIME et l'extension à l'import ; ne pas injecter le SVG brut dans le DOM sans sanitisation ; limiter le rendu à un /canvas
D-07	Régression lors d'une mise à jour de dépendance (@neoledge/vue-ui, Vite, Vue) cassant l'export PNG ou le stockage	2	2	4	Modérée	Suite de tests (voir TESTS_README.md) exécutée avant chaque montée de version
D-08	Perte de travail en cours suite à une fermeture accidentelle de l'onglet pendant la création (pas de sauvegarde automatique)	2	3	6	Modérée	Ajouter une confirmation de fermeture (beforeunload) si un brouillon non sauvegardé existe

Version production — hébergement NeoLedge, données transitant par serveur

#	Risque	I	P	Crit.	Niveau	Mesure préventive
P-01	Fuite de données personnelles (signatures, noms) en transit ou au repos si le chiffrement n'est pas correctement mis en œuvre	4	2	8	Modérée	Forcer HTTPS/TLS de bout en bout ; chiffrement au repos côté base de données NeoLedge ; revue sécurité avant mise en prod
P-02	Absence ou faiblesse de l'authentification/autorisation, permettant à un utilisateur d'accéder aux signatures d'un autre	4	2	8	Modérée	Authentification centralisée NeoLedge (SSO) ; contrôle d'accès par utilisateur/service côté API
P-03	Injection (SQL, XSS stocké) via les champs texte, tampon ou import d'image transmis au serveur	4	2	8	Modérée	Validation et échappement systématiques côté serveur ; requêtes paramétrées ; sanitisation des SVG/images importés
P-04	Indisponibilité du service (panne serveur, surcharge) bloquant la création/consultation de signatures pour tous les utilisateurs	3	2	6	Modérée	Supervision/monitoring, plan de reprise, dimensionnement adapté à la charge attendue
P-05	Non-conformité RGPD : signatures manuscrites et noms constituent des données à caractère personnel, nécessitant base légale, durée de conservation et droits d'accès/suppression	4	3	12	Élevée	Étude d'impact (AIPD) si nécessaire, politique de rétention définie, procédure de suppression sur demande, registre des traitements
P-06	Vol/usurpation de signature : une image de signature exportée peut être réutilisée frauduleusement en dehors de l'application (risque intrinsèque au support image)	3	3	9	Élevée	Positionner clairement l'usage comme signature visuelle non probante juridiquement (sauf intégration à une solution de signature électronique qualifiée) ; traçabilité des exports
P-07	Migration des données existantes du localStorage (version dev) vers le stockage serveur : perte ou corruption lors du passage à l'échelle	2	2	4	Modérée	Aucune migration automatique prévue ; les utilisateurs recréent ou ré-importent leurs signatures via export JSON existant
P-08	Dépendance à l'infrastructure NeoLedge (API interne, @neolledge/foundation) : une évolution non rétrocompatible du socle casse l'application en prod	3	2	6	Modérée	Tests d'intégration avant déploiement, veille sur les versions du socle, environnement de recette avant prod
P-09	Volumétrie de stockage serveur (images/tampons en base64 ou binaire) mal anticipée, coût ou saturation de l'espace disque	2	2	4	Modérée	Limiter/compresser les images à l'upload, quotas par utilisateur, politique d'archivage
P-10	Absence de sauvegarde (backup) côté serveur, perte définitive en cas d'incident	4	1	4	Modérée	Politique de sauvegarde régulière alignée sur les standards d'infrastructure NeoLedge

Synthèse comparative

Aspect	Développement (local)	Production (NeoLedge)
Surface d'attaque	Faible (aucun réseau, un seul poste)	Plus large (réseau, multi-utilisateurs, base de données)
Risque principal	Perte de données locale (D-01)	Conformité RGPD / protection des données personnelles (P-05)
Criticité maximale observée	12 (Élevée)	12 (Élevée)
Priorité d'action avant bascule prod	Sécuriser l'export/sauvegarde manuelle	Authentification, chiffrement, conformité RGPD (P-01, P-02, P-05)